

TRUE-POSITIVE INVESTIGATION LAB

DESIGN VERIFIED: TRUE-POSITIVE LOGIC

Twenty-five controlled scenarios that connect alert behavior to endpoint, identity, network, DNS, cloud, and Microsoft 365 evidence.

25

CONTROLLED SCENARIOS

6

EVIDENCE DOMAINS

5

DECISION STAGES

0

PRODUCTION IMPACT

CLASSIFICATION SCOPE

Methodology verified. Execution evidence was not supplied for independent validation.

Marc Lavoie

Cybersecurity Portfolio | SOC Analysis and Detection Engineering

INDEPENDENT CLASSIFICATION REVIEW

Verification memo

The supplied report was audited against current Microsoft Sentinel incident-classification guidance and the evidence described in each scenario.

CLASSIFICATION LOGIC

VERIFIED

Each scenario defines an alert condition, corroborating telemetry, and controlled ground truth that can support the stated analyst decision.

EXECUTION EVIDENCE

NOT INCLUDED

No incident IDs, timestamps, exported KQL results, screenshots, or raw event records were supplied. Execution cannot be independently confirmed.

PUBLICATION SAFETY

PUBLIC-SAFE

Examples use synthetic identities, lab hosts, reserved addresses, and nonproduction scenarios. No live tenant or company data is required.

AUDIT CONCLUSION

TRUE POSITIVE is supportable at the scenario-design level when the stipulated malicious lab ground truth and the listed telemetry are both present. Suspicious behavior alone is not enough. Until raw records are attached, describe this work as a controlled investigation design rather than a completed production incident investigation.

DECISION DISCIPLINE

One alert, four possible outcomes

A high-quality SOC disposition explains both what the detection observed and why the underlying activity should be treated as malicious, expected, incorrect, or unresolved.

TRUE POSITIVE**Suspicious activity**

The alert is supported by malicious ground truth, scope, impact, or adversary-controlled follow-on behavior.

BENIGN POSITIVE**Suspicious but expected**

The alert logic is reasonable, but a known actor, asset, change, or exercise explains the behavior.

FALSE POSITIVE**Incorrect logic or data**

The rule fired because its logic is wrong for the intended use case, or the supporting data is inaccurate.

UNDETERMINED**Evidence incomplete**

The investigation cannot yet prove malicious intent, expected business context, or a detection defect.

ANALYST GUARDRAIL

Never create a broad allowlist merely because an event was expected once. A useful exception is specific, time-bounded, reviewable, and designed so a real attack still produces signal.

ANALYST WORKFLOW

Five-stage decision framework

The same workflow applies to every scenario. The disposition changes only after the evidence and ground truth converge.

1

VALIDATE

Confirm rule, timestamp, severity, source, and affected entities.

2

SCOPE

Identify users, hosts, files, destinations, and the investigation window.

3

CORRELATE

Pivot across process, file, registry, identity, DNS, network, and cloud data.

4

GROUND TRUTH

Test the activity against change records, lab plans, ownership, and observed impact.

5

DISPOSITION

Close with rationale, response actions, tuning decision, and next validation step.

EVIDENCE DOMAINS

Identity: SigninLogs / AuditLogs | Execution: DeviceProcessEvents | Change: DeviceFileEvents / DeviceRegistryEvents | Network: DeviceNetworkEvents / CommonSecurityLog | Cloud: AzureActivity / OfficeActivity | Case: SecurityAlert / SecurityIncident

COVERAGE MAP

Twenty-five investigation patterns

Each pattern includes an evidence set, ground-truth test, immediate response, and narrow tuning guardrail.

01 Encoded PowerShell Endpoint T1059.001	14 DNS tunneling behavior Network T1071.004
02 PsExec lateral movement Endpoint T1569.002	15 DGA-like NXDOMAIN burst Network T1568.002
03 Scheduled task persistence Endpoint T1053.005	16 RDP brute-force pattern Identity T1110
04 Registry run-key persistence Endpoint T1547.001	17 Password spray Identity T1110.003
05 Rundll32 LOLBin execution Endpoint T1218.011	18 Impossible travel Identity Credential access context
06 Certutil download behavior Endpoint T1105	19 MFA fatigue Identity T1621
07 Data staging and archive creation Endpoint T1560.001	20 New administrative account Identity T1136
08 Ransomware-like mass file changes Endpoint T1486	21 Privileged role assignment Cloud T1098
09 WMI remote execution Endpoint T1047	22 Suspicious OAuth consent Cloud T1528
10 PowerShell remoting and WinRM Endpoint T1021.006	23 Mass SharePoint download M365 T1530
11 Network port scanning Network T1046	24 Suspicious mailbox rule M365 T1114
12 SMB reconnaissance Network T1135	25 Azure firewall or NSG change Cloud T1562.007
13 Command-and-control beaconing Network T1071.001	

SCENARIO SET 01-05

Endpoint and adjacent telemetry

01 Encoded PowerShell

ENDPOINT | T1059.001

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceFileEvents

ACTION

Isolate the host; preserve the command line and process tree.

GROUND-TRUTH TEST

Encoded execution is followed by a download, suspicious child process, or designated malicious payload.

02 PsExec lateral movement

ENDPOINT | T1569.002

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceLogonEvents

ACTION

Contain both endpoints; disable the abused account; collect service-creation evidence.

GROUND-TRUTH TEST

A compromised source executes an unauthorized payload on a second endpoint.

03 Scheduled task persistence

ENDPOINT | T1053.005

PRIMARY EVIDENCE

DeviceProcessEvents, SecurityEvent, DeviceFileEvents

ACTION

Disable the task after capture; collect its action, trigger, and payload.

GROUND-TRUTH TEST

An unauthorized task repeatedly launches a synthetic malicious payload after initial access.

04 Registry run-key persistence

ENDPOINT | T1547.001

PRIMARY EVIDENCE

DeviceRegistryEvents, DeviceProcessEvents

ACTION

Capture the value and payload; remove persistence; hunt for matching keys.

GROUND-TRUTH TEST

A new Run key points to an untrusted user-space payload and creates follow-on execution.

05 Rundll32 LOLBin execution

ENDPOINT | T1218.011

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceImageLoadEvents, DeviceNetworkEvents

ACTION

Terminate the process; quarantine the DLL; trace parent and network activity.

GROUND-TRUTH TEST

Rundll32 loads an untrusted DLL and participates in follow-on malicious activity.

SCENARIO SET 06-10

Endpoint and adjacent telemetry

06 Certutil download behavior

ENDPOINT | T1105

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceFileEvents

GROUND-TRUTH TEST

Certutil retrieves an untrusted executable or script that is subsequently executed.

ACTION

Contain the host; quarantine the artifact; block the source and trace execution.

07 Data staging and archive creation

ENDPOINT | T1560.001

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceFileEvents, DeviceNetworkEvents

GROUND-TRUTH TEST

Sensitive files are staged, archived, and followed by transfer to an unsanctioned destination.

ACTION

Stop transfer; preserve archive and file list; determine exposure and scope.

08 Ransomware-like mass file changes

ENDPOINT | T1486

PRIMARY EVIDENCE

DeviceFileEvents, DeviceProcessEvents, DeviceNetworkEvents

GROUND-TRUTH TEST

Destructive encryption or renaming affects real data and is accompanied by impact indicators.

ACTION

Immediately isolate affected systems; preserve samples; protect backups and shares.

09 WMI remote execution

ENDPOINT | T1047

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceLogonEvents, DeviceNetworkEvents

GROUND-TRUTH TEST

An unauthorized source uses WMI to launch a payload on another endpoint.

ACTION

Contain source and target; preserve WMI and process evidence; block the account.

10 PowerShell remoting and WinRM

ENDPOINT | T1021.006

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceLogonEvents

GROUND-TRUTH TEST

A compromised identity executes unauthorized remote commands with follow-on behavior.

ACTION

Disable the account; preserve remoting telemetry; review destination commands.

SCENARIO SET 11-15

Network and adjacent telemetry

11 Network port scanning

NETWORK | T1046

PRIMARY EVIDENCE

DeviceNetworkEvents, CommonSecurityLog, DeviceProcessEvents

GROUND-TRUTH TEST

A compromised host scans an unusual internal target set before exploitation.

ACTION

Isolate the scanning host; block activity; identify credentials and affected targets.

12 SMB reconnaissance

NETWORK | T1135

PRIMARY EVIDENCE

DeviceNetworkEvents, CommonSecurityLog, DeviceLogonEvents

GROUND-TRUTH TEST

An unauthorized source probes shares and begins failed or successful access attempts.

ACTION

Contain the source; reset exposed credentials; restrict unnecessary SMB paths.

13 Command-and-control beaconing

NETWORK | T1071.001

PRIMARY EVIDENCE

DeviceNetworkEvents, DeviceProcessEvents, CommonSecurityLog

GROUND-TRUTH TEST

Periodic external sessions correlate to an unknown process and designated malicious destination.

ACTION

Isolate the endpoint; block the destination; capture process and network evidence.

14 DNS tunneling behavior

NETWORK | T1071.004

PRIMARY EVIDENCE

ASimDnsActivityLogs, DeviceNetworkEvents, DeviceProcessEvents

GROUND-TRUTH TEST

High-entropy DNS queries carry encoded data to an unauthorized domain.

ACTION

Block the domain; contain the endpoint; identify the responsible process and data scope.

15 DGA-like NXDOMAIN burst

NETWORK | T1568.002

PRIMARY EVIDENCE

ASimDnsActivityLogs, DeviceProcessEvents, DeviceNetworkEvents

GROUND-TRUTH TEST

A suspicious process generates many algorithmic names and reaches a designated malicious endpoint.

ACTION

Block resolved indicators; isolate the endpoint; capture process and DNS history.

SCENARIO SET 16-20

Identity and adjacent telemetry

16 RDP brute-force pattern

IDENTITY | T1110

PRIMARY EVIDENCE

DeviceLogonEvents, SecurityEvent, DeviceNetworkEvents

GROUND-TRUTH TEST

Repeated failures are followed by successful access and suspicious post-authentication activity.

ACTION

Block the source; reset the account; isolate the target; review post-logon activity.

17 Password spray

IDENTITY | T1110.003

PRIMARY EVIDENCE

SigninLogs, IdentityLogonEvents, SecurityAlert

GROUND-TRUTH TEST

One source fails across many accounts and then compromises one or more identities.

ACTION

Reset affected credentials; revoke sessions; block the source; review authentication methods.

18 Impossible travel

IDENTITY | Credential access context

PRIMARY EVIDENCE

SigninLogs, AuditLogs, SecurityAlert

GROUND-TRUTH TEST

Travel cannot be explained by approved VPN egress and is followed by unauthorized actions.

ACTION

Revoke sessions; reset credentials; review risky actions and persistence.

19 MFA fatigue

IDENTITY | T1621

PRIMARY EVIDENCE

SigninLogs, AuditLogs, OfficeActivity

GROUND-TRUTH TEST

A prompt burst is accepted and a new session performs unauthorized actions.

ACTION

Revoke sessions; reset credentials; investigate the accepted prompt and follow-on actions.

20 New administrative account

IDENTITY | T1136

PRIMARY EVIDENCE

AuditLogs, IdentityDirectoryEvents, SigninLogs

GROUND-TRUTH TEST

An unexpected actor creates an account, grants privilege, and begins administrative operations.

ACTION

Disable the account; revoke sessions; reverse changes; audit all actions.

SCENARIO SET 21-25

Cloud and adjacent telemetry

21 Privileged role assignment

CLOUD | T1098

PRIMARY EVIDENCE

AuditLogs, SigninLogs, AzureActivity

ACTION

Remove the role; revoke sessions; review and reverse privileged actions.

GROUND-TRUTH TEST

An anomalous principal assigns a high-impact role and performs follow-on changes.

22 Suspicious OAuth consent

CLOUD | T1528

PRIMARY EVIDENCE

AuditLogs, SigninLogs, AADServicePrincipalSignInLogs

ACTION

Revoke consent and credentials; disable the application; review resources accessed.

GROUND-TRUTH TEST

An unknown application receives broad permissions and accesses organizational resources.

23 Mass SharePoint download

M365 | T1530

PRIMARY EVIDENCE

OfficeActivity, SigninLogs, DeviceNetworkEvents

ACTION

Revoke the session; stop transfer; preserve audit logs; assess exposed content.

GROUND-TRUTH TEST

An identity collects sensitive files and transfers them to an unsanctioned destination.

24 Suspicious mailbox rule

M365 | T1114

PRIMARY EVIDENCE

OfficeActivity, AuditLogs, SigninLogs

ACTION

Capture and remove the rule; revoke sessions; inspect forwarded or deleted mail.

GROUND-TRUTH TEST

A suspicious session creates a rule that hides, deletes, or externally forwards sensitive mail.

25 Azure firewall or NSG change

CLOUD | T1562.007

PRIMARY EVIDENCE

AzureActivity, SigninLogs, AuditLogs, CommonSecurityLog

ACTION

Restore secure policy; revoke the actor; review exposure and traffic during the window.

GROUND-TRUTH TEST

An unauthorized actor creates broad access and traffic confirms the defensive control was weakened.

WORKED INVESTIGATION

Command-and-control beaconing

A repeated outbound pattern is a detection signal, not a final verdict. The analyst must connect timing, process lineage, destination ownership, identity context, and impact.

1

ALERT

SecurityAlert identifies the host, rule, severity, and investigation window.

2

NETWORK

DeviceNetworkEvents and CommonSecurityLog confirm stable periodic connections.

3

PROCESS

DeviceProcessEvents ties the sessions to a process, parent, path, signer, and account.

4

CHANGE

DeviceFileEvents shows when the process and any configuration artifact appeared.

5

CONTEXT

Change records, test plan, destination ownership, and follow-on behavior establish ground truth.

DISPOSITION

TRUE POSITIVE only when the process is designated malicious or unauthorized and the independent telemetry shows adversary-like follow-on activity. Response: isolate, block, preserve evidence, scope related hosts, and eradicate the persistence or payload.

OPERATIONAL QUALITY

From disposition to better detection

The investigation should improve both immediate response and future signal quality. Every closure needs a rationale, owner, evidence list, and reviewable next step.

CONTAIN	SCOPE	IMPROVE
● Isolate affected endpoints ● Disable or restrict compromised identities ● Block confirmed destinations and indicators ● Preserve volatile and cloud-session evidence	● Hunt for the same process, hash, account, or destination ● Build the timeline before and after the first alert ● Identify affected users, systems, and data ● Separate confirmed impact from unverified concern	● Document why the alert was correct ● Add entity mapping and investigation context ● Tune severity or grouping only with evidence ● Retest against both malicious and benign controls

MINIMUM CLOSURE NOTE

Disposition + classification reason + alert rule + investigation window + affected entities + telemetry reviewed + ground-truth evidence + observed impact + response taken + tuning decision + owner + follow-up date.

VERIFICATION NOTES

References, limitations, and next proof

WHAT THIS REPORT ESTABLISHES

A technically coherent true-positive investigation design across twenty-five common behaviors, including required telemetry, malicious ground truth, response actions, and the rule that suspicious behavior alone is not proof.

WHAT REMAINS TO PROVE

Attach sanitized incident metadata, KQL output, timestamps, entity pivots, and closure evidence from an executed lab. Until then, this is a portfolio engineering design, not independent proof of live execution.

Microsoft Sentinel incident investigation

<https://learn.microsoft.com/en-us/azure/sentinel/investigate-incidents>

Microsoft Sentinel incident classification

<https://learn.microsoft.com/en-us/azure/sentinel/incident-navigate-triage>

Handling false positives in Microsoft Sentinel

<https://learn.microsoft.com/en-us/azure/sentinel/false-positives>

Defender XDR advanced hunting - DeviceProcessEvents

<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>

MITRE ATT&CK data components

<https://attack.mitre.org/datacomponents/>

PORTFOLIO STATEMENT

Prepared by Marc Lavoie as a public-safe cybersecurity portfolio case study. The report demonstrates investigative reasoning, not access to any production tenant or confidential incident.